

RELATÓRIO DO SCAN PASSIVO COM OWASP ZAP: FINDINGS DE SEVERIDADE MÉDIA E ALTA

1. Authentication Credentials Captured.

1.1. Finding

Authentication Credentials Captured.

1.2. Severidade

High.

1.3. Confiança

Não listada.

1.4. URL afetada

<http://127.0.0.1:8000/auth/token>

1.5. O que foi detectado

O OWASP ZAP detectou que o endpoint `/auth/token` utiliza autenticação Basic Authentication, transmitindo as credenciais no cabeçalho da requisição.

1.6. Por que é um problema

Basic Authentication não fornece criptografia das credenciais por si só. As credenciais podem ser recuperadas por alguém capaz de interceptar o tráfego, especialmente quando a comunicação ocorre por HTTP em vez de HTTPS.

No ambiente local, a URL utilizada pelo teste é <http://127.0.0.1:8000/auth/token>. Portanto, a comunicação não está protegida por TLS.

1.7. Correção realizada

A correção deve garantir que, em ambiente de produção, o endpoint de autenticação seja disponibilizado exclusivamente por HTTPS, impedindo que credenciais sejam transmitidas por conexões HTTP não protegidas.

Neste projeto, a API foi desenvolvida para fins de demonstração e execução em ambiente local. Dessa forma, o uso de HTTP está restrito ao ambiente de desenvolvimento local e não representa a configuração prevista para um ambiente de produção.

Em uma eventual implantação em produção, a comunicação deverá ser protegida por HTTPS, garantindo a confidencialidade das credenciais e reduzindo o risco de interceptação de informações durante o processo de autenticação.

1.8. Validação

Após a correção/configuração de HTTPS, executar novamente o passive scan do ZAP e verificar se o alerta Authentication Credentials Captured não é mais reportado para /auth/token.

1.9. Risco aceito, se não corrigido

No ambiente local de desenvolvimento, o risco pode ser aceito temporariamente porque a API está vinculada a 127.0.0.1. Entretanto, esse risco não deve ser aceito em um ambiente exposto à rede. HTTPS deve ser utilizado antes da implantação.

2. Content Security Policy Header Not Set

2.1. Finding

Content Security Policy (CSP) Header Not Set

2.2. Severidade

Medium

2.3. Confiança

Não listada.

2.4. URL afetada

<http://127.0.0.1:8000/docs>

2.5. O que foi detectado

O ZAP detectou que a resposta da página /docs não contém o cabeçalho Content-Security-Policy.

2.6. Por que é um problema

Uma CSP permite restringir quais scripts, estilos, imagens e outros recursos podem ser carregados pelo navegador. A ausência desse cabeçalho reduz uma camada de proteção contra determinados ataques, incluindo XSS e injeção de conteúdo.

2.7. Correção realizada

Adicionar um middleware que forneça uma política CSP apropriada.

2.8. Validação

Executar novamente o passive scan no ZAP.

2.9. Risco aceito, se não corrigido

O /docs está sendo utilizado apenas em desenvolvimento e não será exposto publicamente, o risco é temporariamente aceito. Para uma aplicação exposta, recomenda-se implementar CSP.

3. Cross-Domain Misconfiguration

3.1. Finding

Cross-Domain Misconfiguration.

3.2. Severidade

Medium.

3.3. Confiança

Não listada.

3.4. URL afetada

<https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js>

<https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css>

3.5. O que foi detectado

O ZAP identificou o cabeçalho: Access-Control-Allow-Origin: * nos recursos disponibilizados pelo CDN jsDelivr utilizados pelo Swagger UI. Entretanto, a configuração CORS da aplicação FastAPI é restritiva.

3.6. Por que é um problema

O valor Access-Control-Allow-Origin: * pode representar um risco quando aplicado a uma API que disponibiliza dados sensíveis, pois permite requisições cross-origin de qualquer origem em determinadas situações. Porém, esse não é o caso da configuração apresentada da aplicação. O alerta do ZAP refere-se aos recursos estáticos externos do jsDelivr, enquanto o CORS da API utiliza ALLOWED_ORIGINS e não permite credenciais via cookies. Portanto, o finding não evidencia uma configuração CORS permissiva na própria API.

3.7. Correção realizada

Nenhuma alteração no CORS da aplicação é necessária com base neste finding.

3.8. Validação

A configuração deve ser validada diretamente contra a API, e não contra o CDN.

3.9. Risco aceito, se não corrigido

O finding pode ser aceito como risco de terceiro.

4. Sub Resource Integrity Attribute Missing.

4.1. Finding

Sub Resource Integrity Attribute Missing.

4.2. Severidade

Medium.

4.3. Confiança

Não listada.

4.4. URL afetada

<http://127.0.0.1:8000/docs>

<https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css>

<https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js>

4.5. O que foi detectado

Os recursos externos carregados pelo Swagger UI não possuem o atributo `integrity=...`

4.6. Por que é um problema

Subresource Integrity permite que o navegador verifique se o arquivo recebido de um servidor externo corresponde exatamente ao arquivo esperado. Sem SRI, se o conteúdo de um recurso externo fosse alterado, o navegador poderia carregar o conteúdo modificado.

4.7. Correção realizada

Neste projeto, o finding está limitado ao ambiente de desenvolvimento e à interface Swagger UI. Não é necessária uma alteração na lógica ou nos mecanismos de autenticação da API para tratar esse alerta.

4.8. Validação

A validação deve verificar especificamente a interface `/docs`.

4.9. Risco aceito, se não corrigido

Como o finding está relacionado somente aos recursos da interface Swagger UI utilizada durante o desenvolvimento, o risco pode ser aceito quando `/docs` não estiver disponível publicamente em produção.